ISO 27001 Dummy Project: Identifikasi Risiko

Oct 21, 2026 · @Ali Abdulloh

Identifikasi risiko adalah langkah 2 (Klausul 6.1.2 c dan d): mencari apa saja yang bisa mengganggu kerahasiaan, integritas, atau ketersediaan aset di scope. Belum ada penilaian angka di sini; penilaian dilakukan di langkah 3.

Istilah yang dipakai

- **Ancaman:** hal yang bisa menyebabkan kerugian, misalnya penyerang atau gangguan layanan.
- **Kerentanan:** kelemahan yang bisa dimanfaatkan ancaman, misalnya hak akses terlalu luas.
- **Risiko:** ancaman yang memanfaatkan kerentanan pada sebuah aset. Ditulis sebagai skenario satu kalimat.
- **Pemilik risiko:** pihak yang bertanggung jawab atas risiko itu dan berwenang menyetujui penanganannya.

Daftar Skenario Risiko

Cara baca satu baris: ancaman memanfaatkan kerentanan pada aset, sehingga terjadi skenario risiko, dan pemilik risiko bertanggung jawab. Satu aset bisa punya lebih dari satu risiko.

ID	Aset	Ancaman	Kerentanan	Skenario risiko	Pemilik risiko
R-01	A-01 Database transaksi	Serangan injeksi SQL	Validasi input lemah, patch terlambat	Data transaksi dicuri atau dimanipulasi lewat celah aplikasi	Head of Engineering
R-02	A-02 Data KYC pengguna	Akses tidak sah oleh orang dalam	Hak akses terlalu luas, MFA belum diterapkan	Data KTP dan swafoto pengguna bocor atau disalahgunakan	Compliance Officer
R-03	A-02 Data KYC pengguna	Salah konfigurasi penyimpanan	Object storage bisa diakses publik karena konfigurasi keliru	File KYC terekspos ke internet	Head of Infrastructure
R-04	A-03 Saldo dan ledger	Manipulasi data oleh pihak internal	Tidak ada pemisahan tugas, rekonsiliasi manual	Saldo atau mutasi diubah tanpa terdeteksi	Head of Finance Operations
R-05	A-04 Kunci enkripsi dan secret	Kebocoran kredensial	Secret tersimpan di kode atau channel chat	Kunci jatuh ke penyerang sehingga data	Head of Security

				terenkripsi bisa dibuka	
R-06	A-05 Kode sumber dan pipeline CI/CD	Pencurian atau pengungkapan kode sumber oleh pihak tidak berwenang	Akses repositori tanpa MFA, akun mantan karyawan masih aktif, repositori bisa dipublikasikan tanpa kontrol	Kode sumber bocor sehingga celah aplikasi dan logika bisnis terlihat pihak yang tidak berwenang	Head of Engineering
R-07	A-05 Kode sumber dan pipeline CI/CD	Modifikasi kode atau pipeline oleh pihak tidak berwenang (supply chain)	Akses repositori dan pipeline tanpa MFA, akun mantan karyawan masih aktif, belum ada branch protection dan review wajib	Kode atau pipeline diubah tanpa izin sehingga kode berbahaya masuk ke produksi dan dana atau data pengguna disalahgunakan	Head of Engineering
R-08	A-06 Dokumen kebijakan dan kontrak	Perubahan atau kehilangan tanpa izin	Tidak ada kontrol versi dan hak akses dokumen	Kebijakan usang atau berubah tanpa persetujuan, kewajiban hukum terlewat	Compliance Officer
R-09	A-07 Aplikasi mobile	Aplikasi tiruan atau modifikasi aplikasi	Tidak ada proteksi integritas aplikasi	Aplikasi palsu mencuri kredensial pengguna	Product Owner
R-10	A-08 API payment gateway	Serangan DDoS	Tidak ada rate limiting dan proteksi DDoS memadai	API tidak tersedia, transaksi merchant gagal	Head of Engineering
R-11	A-08 API payment gateway	Penyalahgunaan API	Otorisasi per objek lemah	Penyerang mengakses transaksi merchant lain	Head of Engineering
R-12	A-09 Dasbor merchant	Pengambilalihan akun (credential stuffing)	Kebijakan kata sandi lemah, MFA opsional	Akun merchant diambil alih dan dana dialihkan	Product Owner
R-13	A-10 Monitoring dan log	Log hilang atau tidak memadai	Log tidak dilindungi, retensi singkat, tanpa alerting	Insiden tidak terdeteksi atau tidak bisa diselidiki	Head of Security

R-14	A-11 Infrastruktur cloud	Gangguan layanan penyedia cloud	Tidak ada arsitektur multi-zona dan rencana pemulihan teruji	Layanan berhenti berjam-jam	Head of Infrastructure
R-15	A-11 Infrastruktur cloud	Ransomware	Backup tidak terisolasi dan tidak pernah diuji pulihkan	Data produksi terenkripsi dan backup ikut rusak	Head of Infrastructure
R-16	A-12 Jaringan kantor	Akses jaringan tidak sah	Segmentasi jaringan lemah	Penyerang di jaringan kantor menjangkau sistem internal	Head of Infrastructure
R-17	A-13 Laptop karyawan	Laptop hilang atau dicuri	Disk belum terenkripsi, tidak ada manajemen perangkat	Data perusahaan bocor dari laptop	Head of IT Support
R-18	A-13 Laptop karyawan	Phishing dan social engineering	Kesadaran keamanan rendah, filter email longgar	Karyawan menyerahkan kredensial dan penyerang masuk ke sistem	Head of IT Support
R-19	A-14 Integrasi bank mitra dan QRIS	Gangguan atau kompromi koneksi mitra	Kredensial integrasi jarang diganti, tidak ada failover	Transaksi tertahan atau disusupi	Head of Partnership
R-20	A-15 Layanan KYC pihak ketiga	Kebocoran data di sisi penyedia	Tidak ada penilaian keamanan vendor, klausul keamanan di kontrak belum jelas	Data KYC pengguna bocor dari penyedia	Compliance Officer
R-21	A-16 Layanan SMS OTP pihak ketiga	Gangguan layanan atau penyadapan OTP	Bergantung pada satu penyedia tanpa cadangan, OTP dikirim lewat SMS	Pengguna tidak bisa login atau bertransaksi, atau OTP disalahgunakan	Head of Engineering
R-22	A-17 Personel kunci	Kehilangan personel atau penyalahgunaan akses karyawan keluar	Ketergantungan pada satu orang, offboarding tidak teratur	Pengetahuan kritis hilang dan akses mantan karyawan masih aktif	Head of HR

Skenario di atas masih berupa usulan awal. Penilaian kemungkinan dan dampaknya dikerjakan di langkah 3.